

# WebBartosz Portfolio — Authentication and Authorization

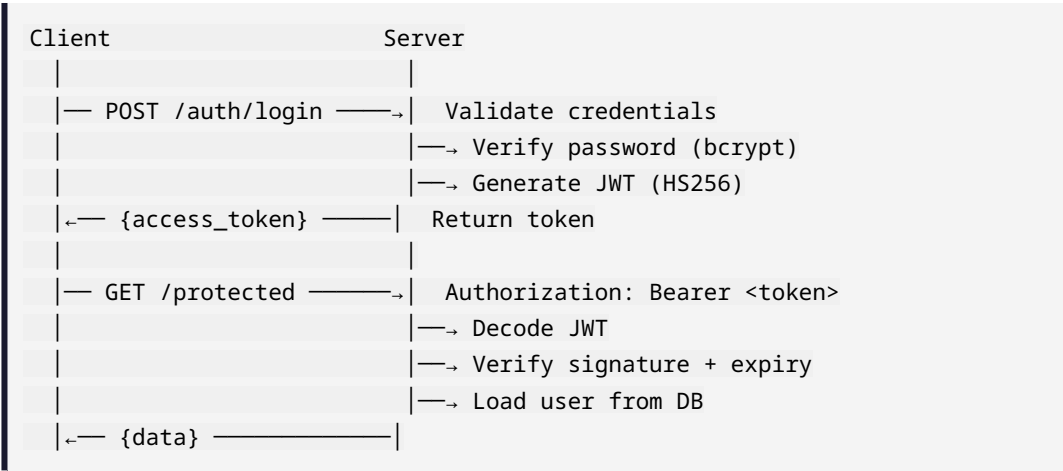
**Project:** WebBartosz Portfolio  
**Technology:** Vite, vanilla JavaScript, CSS3, HTML5  
**Location:** /home/dominic/Documents/WebBartosz  
**Report #:** 6/20

## No Authentication

Static site, no user accounts.

## Authentication & Authorization System

### Auth Flow



### JWT Configuration

| Parameter | Value                              | Notes                                |
|-----------|------------------------------------|--------------------------------------|
| Algorithm | HS256                              | Symmetric signing                    |
| Expiry    | 30 days                            | Configurable via ACCESS_TOKEN_EXPIRE |
| Header    | Authorization: Bearer              | Standard Bearer scheme               |
| Payload   | {"sub": user_id, "exp": timestamp} | Standard JWT claims                  |

### Password Security

- Hashing algorithm: bcrypt (via passlib)

- Salt: automatic (bcrypt built-in)
- Minimum password length: 8 characters
- No plaintext storage ever

### Protected Routes

- POST /urls/shorten (JWT required)
- GET /urls/list (JWT required)
- DELETE /urls/{code} (JWT + ownership)
- POST /api/chat/message (JWT required)
- POST /api/rag/upload (JWT required)

### Permission Model

- Resource ownership: users can only modify their own resources
- No role-based access currently (admin/user distinction not implemented)
- Future: add is\_admin flag for elevated permissions

### Security Headers (Recommended)

| Header                    | Value            | Purpose               |
|---------------------------|------------------|-----------------------|
| X-Content-Type-Options    | nosniff          | Prevent MIME sniffing |
| X-Frame-Options           | DENY             | Prevent clickjacking  |
| Strict-Transport-Security | max-age=31536000 | Force HTTPS           |